PUC Minas

PUC Minas

APRESENTAÇÃO

Edgar Paes

PUC Minas

DevSecOps: Segurança Integrada e Scanning

APRESENTAÇÃO DO PROFESSOR - ACADÊMICO

Edgar Paes Cassemiro

- Graduado em Gestão da Tecnologia da Informação (UNI-BH)
- Pós-Graduado em Segurança da Informação (FACE/FUMEC)
- Pós-Graduação em Redes de Computadores (PUC-MG)
- Mestrado em Informática/Ciência da Computação (PUC-MG)
- MBA em Segurança de Dados (USP)
- Extensão em Engenharia de Software Moderna (UFMG)

APRESENTAÇÃO DO PROFESSOR – CERTIFICAÇÕES

- ISC^2 - CISSP (Certified Information System Security Professional)
- EC-Council - C|CISO (Certified Chief Information Security Officer)
- EC-Council Certified DevSecOps Engineer (ECDE)
- EC-Council Certified Encryption Specialist (E|CES)
- CompTIA – SecurityX (Cybersecurity Expert)
- CompTIA - CySA+ (Cybersecurity Analyst)
- CREST - CPSA (CREST Practitioner Security Analyst)
- EC-Council - ECSA (EC-Council Certified Security Analyst)
- EC-Council - CEH (Certified Ethical Hacker)

APRESENTAÇÃO DO PROFESSOR – CERTIFICAÇÕES

- EXIN - PDPP (Privacy and Data Protection Professional)
- EXIN - PDPF (Privacy and Data Protection Foundation)
- EXIN - ISFS (Information Security Foundation)
- EXIN - EHF (Ethical Hacker Foundation)
- BSI – ISO/IEC 27001:2022 Lead Auditor
- BSI – ISO/IEC 27001:2022 Internal Auditor
- PECB - ISO/IEC 27001:2022 Senior Lead Implementer
- EC-Council Cybersecurity Career Mentor

APRESENTAÇÃO DO PROFESSOR – EXPERIÊNCIA

- Experiência de mais de 15 (quinze) anos atuando com segurança da informação e cibernética
- Experiência em empresas do setor Financeiro, Saúde, Logística, Mídias Digitais, Tecnologia, Data Center
- Atuação como arquiteto de segurança, consultor de segurança e auxiliar de perícia forense digital

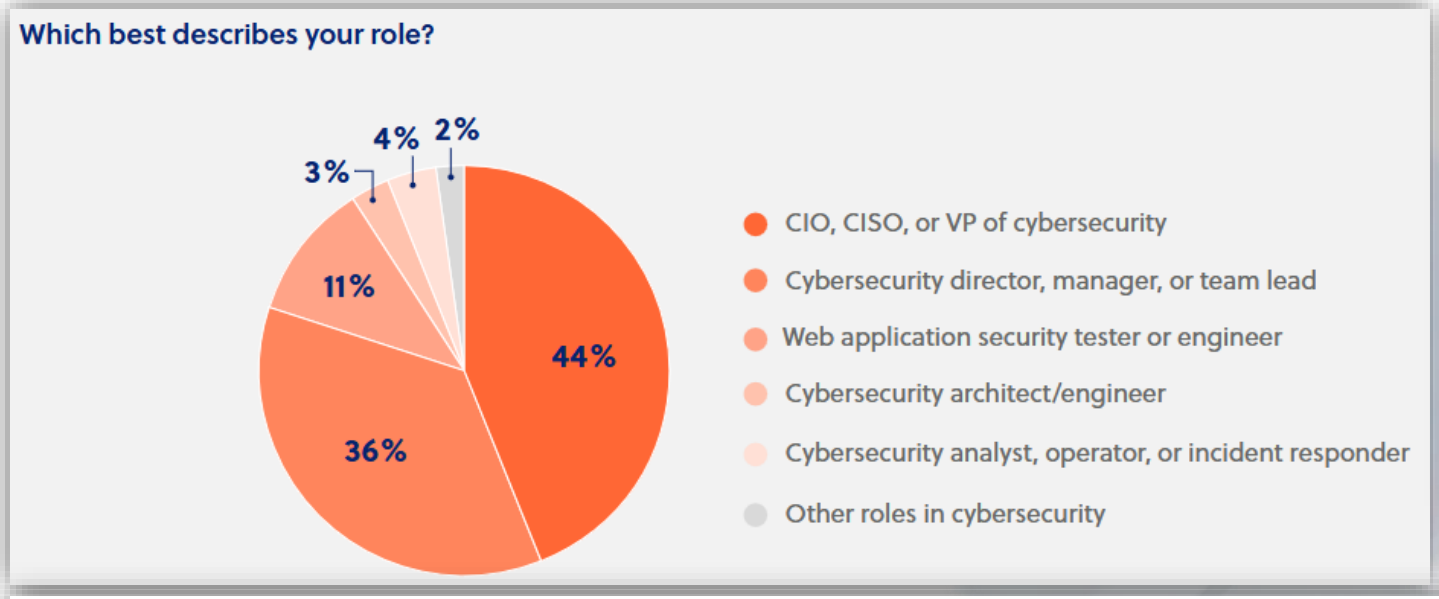
ASSUNTOS ABORDADOS (EMENTA)

Fundamentos de DevSecOps: segurança em ambientes ágeis e Security by Design. SDLC (Secure Development Lifecycle) e práticas de segurança contínua. Implementação de segurança end-to-end em pipelines CI/CD. Ferramentas e técnicas de verificação: IAST, SAST, DAST, RASP. Security Observability: métricas, logs, tracing aplicados à segurança. IA aplicada para análise de vulnerabilidades e threat intelligence. Melhores práticas de DevSecOps em ambientes cloud-native. Projeto prático: construção de pipeline DevSecOps com segurança integrada

ASPECTOS CENTRAIS DA DISCIPLINA

- Não há implantação de quaisquer soluções de segurança (vendor-neutral)
- Não há aprofundamentos técnicos
- Foco e condução baseado arquitetura e design
- Foco em capital epistemológico, metodologias e práticas do processo do tema
- Horas de estudo **recomendada**: 5 - 8h semanais

CENÁRIO DE SEGURANÇA DE APLICAÇÕES





Demographics

This report is based on a survey of 349 qualified professionals from the United States and United Kingdom. Participants were required to hold full-time positions as cybersecurity leaders or practitioners, with significant hands-on experience discovering, testing, and remediating vulnerabilities in public-facing web applications, or supervising others who do so. Respondents' roles included Chief Information Security Officer (CISO), Chief Information Officer (CIO), VP of Cybersecurity, and Cybersecurity Director, Manger, or Team Lead. Other participants were web application security testers and engineers, as well as cybersecurity architects, engineers, analysts, operators, and incident responders.

Fonte: https://www.cycognito.com. 2024 State of Web Application Security Testing.

CENÁRIO DE SEGURANÇA DE APLICAÇÕES

- **Organizations are exposing 100s of web applications.** Web application attack surfaces are large and growing. Survey participants' organizations maintain dozens if not hundreds of custom web apps developed in-house and by third-party partners.

- **Over 25% experience a major web application security incident every week.** Web application security incidents and breaches are common. More than one-third of respondents (35%) experience a significant security event involving a web app at least once a week, while more than one-quarter (26%) experience a major incident that often.

- **Nearly 75% test their web applications monthly or less often, leaving more than 40% of the attack surface untested.** Web application security testing is conducted infrequently and coverage is lacking. Most respondents are testing fewer than half of their organization's web applications monthly or less often. More than one in four survey participants (26%) work for organizations with no formal process for testing production web applications. This isn't enough to effectively mitigate web application security risks.

- **65% are planning to increase automation within their web application security testing workflows.** Looking to the future, they are interested in creating efficiencies. They are also interested in building out continuous testing capabilities.

Fonte: https://www.cycognito.com. 2024 State of Web Application Security Testing.

CENÁRIO DE SEGURANÇA DE APLICAÇÕES



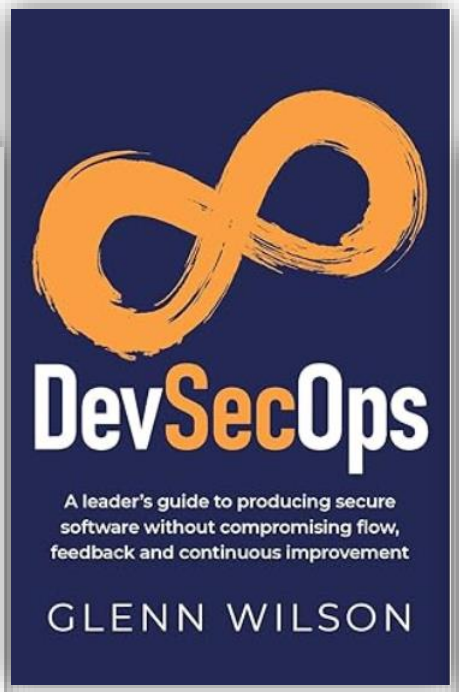
PARA PENSAR...

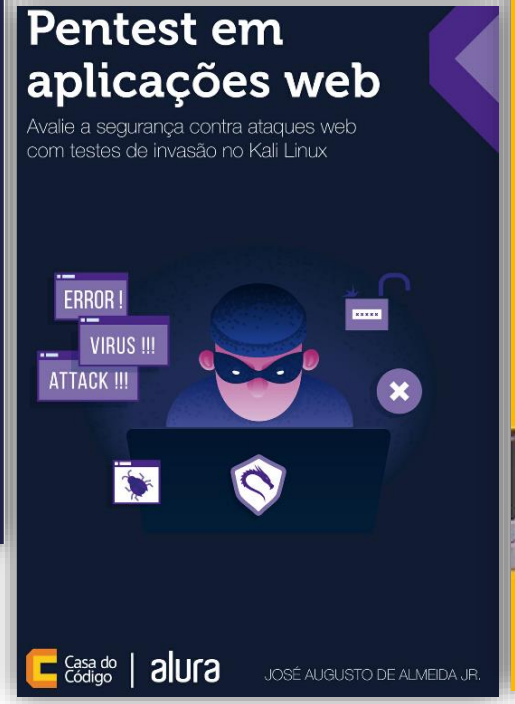
- Uma organização realiza para fins de conformidade regulatória, Testes de Intrusão (Pentest) regularmente em suas aplicações Web críticas de negócio, pelo menos, uma vez a cada seis meses. Considerando o cenário atual de grandes mudanças nas aplicações devido ao grande número de implantações (deploy) diariamente, quais as implicações de segurança?

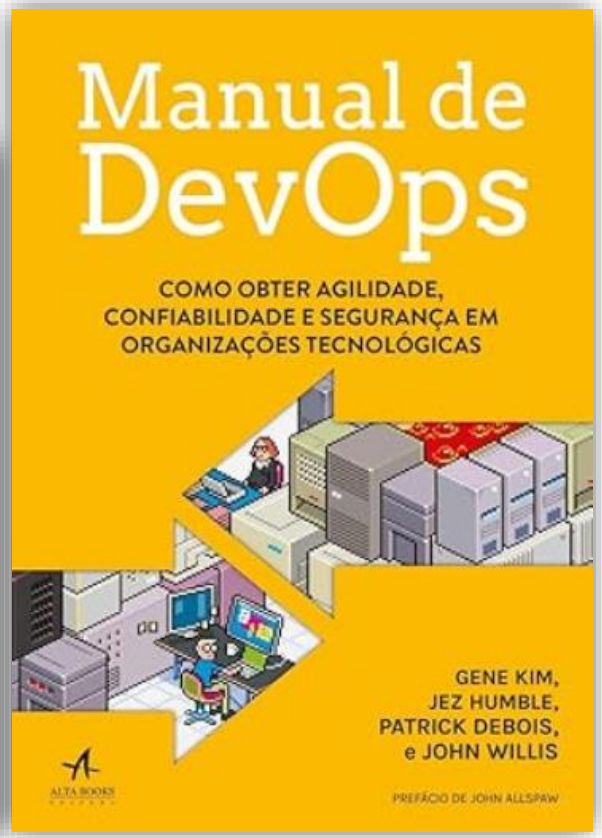
BIBLIOGRAFIA











BONS ESTUDOS!

Bons Estudos!!!

PUC Minas